

Narrativa Explicativa de la Encuesta CRA

1. Por qué esta encuesta existe

En algún punto entre la proliferación de dispositivos conectados y la constatación de que los parches nunca llegan tan rápido como los exploits, la Unión Europea decidió que quizá era hora de exigir un cierto nivel de seriedad estructural a los productos con elementos digitales. El resultado tiene un nombre solemne —Cyber Resilience Act— y una consecuencia práctica: fabricar, distribuir o explotar tecnología conlleva ahora obligaciones medibles.

Esta encuesta nace precisamente para eso: para poner números —y no sólo opiniones— a la preparación de las organizaciones frente al CRA. No pretende ser un examen ni un ritual de culpa, sino un instrumento para entender dónde estamos, qué nos falta y qué puede hacerse mejor.

2. Qué se intenta medir, realmente

Hay tres grandes preguntas que sobrevuelan el cuestionario:

1. ¿Sabemos de qué va el CRA, más allá del titular?
2. ¿Tenemos procesos, personas y tecnología para cumplirlo sin convertir cada lanzamiento en una tragedia regulatoria?
3. ¿Somos capaces de medir lo anterior con algo más sólido que la intuición?

Cada sección de la encuesta apunta a un ángulo distinto de estas preguntas. El hilo conductor es la idea de madurez: no sólo cumplir lo mínimo para evitar sanciones, sino integrar los requisitos del CRA en la estrategia de producto, en la arquitectura de seguridad y en la cultura organizativa.

3. Cómo leer las preguntas (y cómo no)

Las preguntas están formuladas en un lenguaje lo más claro posible, con algún guiño literario aquí y allá para recordarnos que seguimos siendo humanos. No hace falta conocer el articulado completo del CRA para entenderlas, aunque ayuda.

Conviene leer las opciones de respuesta como posiciones en un continuo de madurez, más que como casillas “correctas” o “incorrectas”. No pasa nada por marcar opciones que empiecen por “No” o “Todavía no”; de hecho, son estadísticamente inevitables, y a menudo las más útiles para tomar decisiones.

4. Qué se hará con las respuestas

En función del contexto en que se administre la encuesta, las respuestas pueden utilizarse para:

- Elaborar un informe interno, que ayude a priorizar inversiones, proyectos de refactorización de productos, refuerzo de capacidades o cambios de gobernanza.
- Alimentar un estudio sectorial o nacional, comparando niveles de preparación entre organizaciones, sectores o países.
- Complementar otras fuentes de datos (por ejemplo, métricas de vulnerabilidades, incidentes o certificaciones) para construir indicadores más completos de ciberresiliencia.

En todos los casos, vale la pena recordar que los números no son un fin en sí mismos. Su función es iluminar decisiones, no sustituirlas.

5. Sobre el IGM y el ROI

El Índice Global de Madurez (IGM) no pretende ser una sentencia ontológica sobre la virtud cibernética de nadie, sino un artefacto útil para contestar preguntas como:

- ¿Estamos mejor este año que el pasado?
- ¿Estamos en la media de nuestro sector, por encima o por debajo?
- ¿Dónde están nuestras brechas más claras (gobernanza, producto, vulnerabilidades, datos, capacidades)?

En cuanto al ROI, conviene abordarlo con humildad metodológica. Es posible —y deseable— estimar órdenes de magnitud: cuánto invertimos en adaptar productos y procesos al CRA y cuánto hemos dejado de perder (o podemos razonablemente esperar dejar de perder) al reducir la probabilidad o el impacto de incidentes.

Lo que no es razonable es esperar el tipo de precisión milimétrica que uno asociaría, por ejemplo, a una planta solar con contador bidireccional. La ciberresiliencia opera en el terreno de los escenarios y las probabilidades, y así debe interpretarse.

6. Un comentario sobre el tono

Aunque hablamos de temas muy serios —riesgos sistémicos, incidentes, pérdidas, responsabilidades—, el tono deliberadamente no es lúgubre. La experiencia sugiere que, si queremos que la gente responda con honestidad, conviene permitir cierto margen para la ironía, el reconocimiento de las dificultades y la posibilidad de admitir que nadie lo hace todo bien.

La ironía, aquí, no es cinismo: es una manera de aceptar que la perfección no existe y que el objetivo razonable es mejorar de forma sistemática, no alcanzar una hipotética “seguridad absoluta”.

7. Y ahora, qué

Una vez completada la encuesta, el siguiente paso natural es:

- Revisar el diagnóstico cuantitativo (puntuaciones, niveles de madurez).
- Leer con atención las respuestas abiertas, donde a menudo se cuecen los matices importantes.
- Traducir las conclusiones en un plan de acción: decisiones concretas sobre qué reforzar, qué dejar de hacer y qué priorizar en los próximos 12–24 meses.

Si la encuesta se ha administrado a varias organizaciones (por ejemplo, en un sector o país), el ejercicio adquiere además una dimensión colectiva: permite detectar patrones, brechas estructurales y oportunidades de colaboración o de política pública.

Al final del día, la pregunta más interesante no es “¿cuál es nuestra puntuación CRA?”, sino “¿qué vamos a hacer con lo que acabamos de descubrir?”.